

The cover features a dark blue background with abstract yellow and light grey shapes in the corners. Decorative white dashed lines with yellow circles are positioned in the top right and bottom left corners. The title 'API Security Risk Analysis' is centered in a large, white, serif font.

API Security Risk Analysis

Comprehensive Security Assessment Report



Introduction

API security is a critical component of modern software development, essential for protecting sensitive data and preventing unauthorized access to systems and services. As organizations increasingly rely on APIs to connect applications, share data, and enable integrations, the attack surface for potential security breaches continues to expand.

Without proper security measures, APIs can expose confidential information, allow malicious actors to manipulate data, and create vulnerabilities that compromise entire systems. This report analyzes the security posture of a target API to identify potential risks and provide actionable recommendations for improvement.



API Overview

Target API:

<https://jsonplaceholder.typicode.com/users>

This publicly accessible REST API endpoint returns user data including names, emails, addresses, and contact information. The API was selected for security analysis due to its open nature and common usage patterns.

Tools Used:

- Browser DevTools - For inspecting network requests, analyzing API responses, and examining headers and payload data
- Public API (Canva) - For documentation review and endpoint testing capabilities

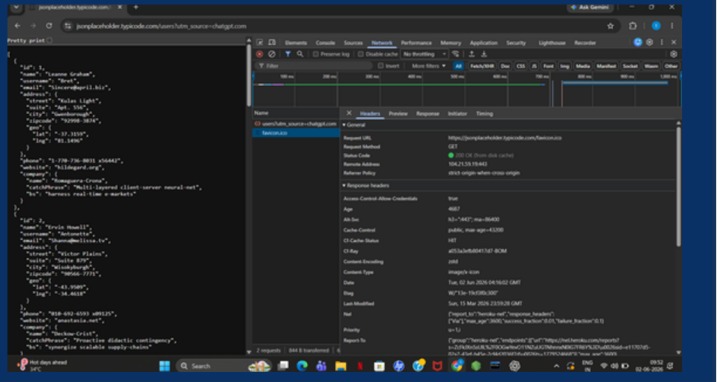
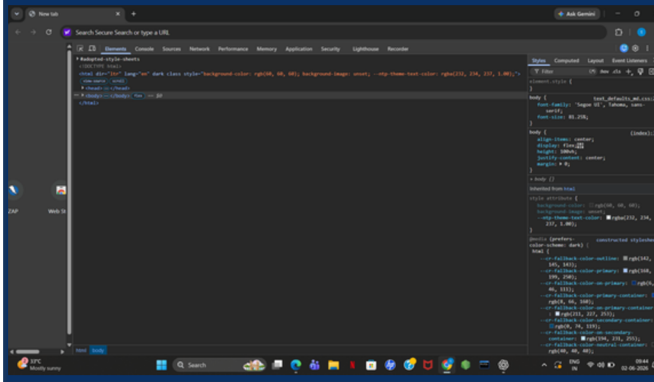
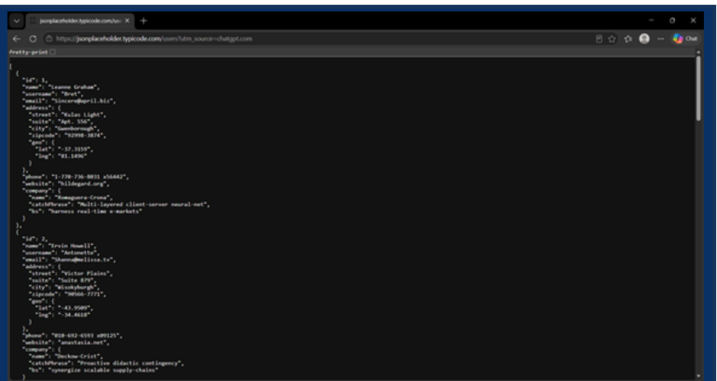
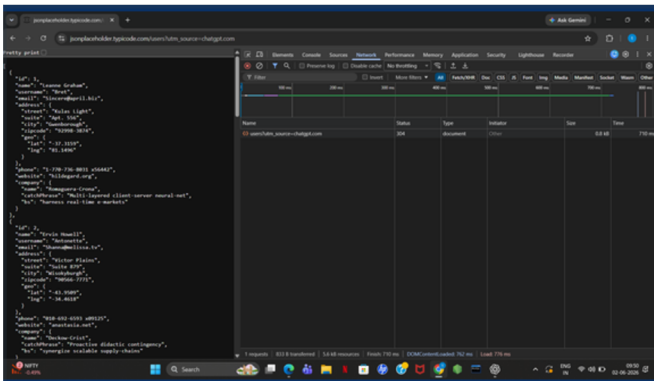


Findings Table

Finding	Severity
No Authentication	High
Data Exposure	Medium
Missing Rate Limiting	Medium
Input Validation Issues	Medium

The security assessment revealed four key findings. The most critical issue is the lack of authentication, allowing unrestricted API access. Additional medium-severity concerns include unnecessary data exposure in responses, absence of rate limiting controls, and insufficient input validation mechanisms.







Screenshots

API Response Screenshot

This screenshot captures the raw JSON response from the JSONPlaceholder API endpoint, displaying user data including names, emails, addresses, and phone numbers. The exposed data demonstrates the potential privacy risks when APIs return excessive information without proper filtering.

Browser DevTools Screenshot

This screenshot shows the Network tab in Browser DevTools, revealing the API request headers, response headers, and timing information. Key observations include the absence of authentication tokens and the lack of security headers in the response.



Recommendations

Implement Authentication

Secure your API endpoints by requiring proper authentication mechanisms such as API keys, OAuth tokens, or JWT. This prevents unauthorized users from accessing sensitive data and functionality.

Use Rate Limiting & Validate Inputs

Implement rate limiting to prevent API abuse and DDoS attacks. Additionally, validate all user inputs to protect against injection attacks and ensure data integrity. Minimize data exposure by returning only necessary fields in API responses.



Conclusion

The API security assessment of JSONPlaceholder identified multiple critical vulnerabilities that require immediate attention. The lack of authentication mechanisms poses the highest risk, allowing unauthorized access to sensitive user data. Additionally, the absence of rate limiting creates opportunities for abuse through automated attacks and denial of service.

Data exposure concerns were also identified, with the API returning more information than necessary for typical use cases. Combined with input validation issues, these findings highlight the need for a comprehensive security review. Implementing the recommended controls will significantly improve the API's security posture and protect against common attack vectors.

